

# Model-driven Privacy



Srđan Krstić



Hoàng Nguyễn

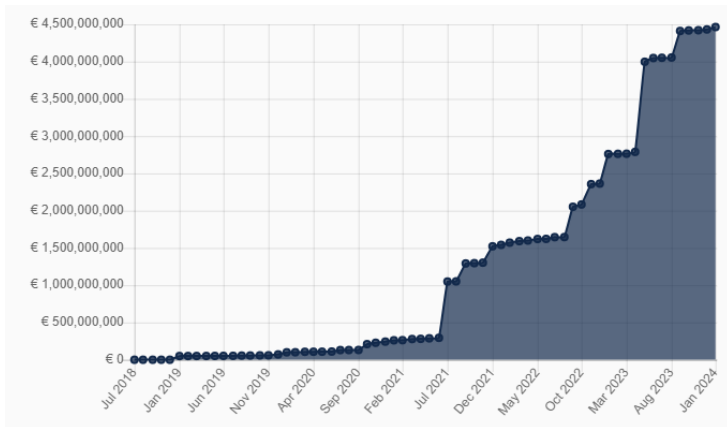


David Basin

Information Security Group  
Computer Science Department  
ETH Zürich, Switzerland

PETS 24, Bristol, UK

# GDPR sum of fines and penalties



# Privacy requirements

## Source of requirements:

- Privacy regulations: GDPR, CCPA, DCIA, PIPL
- User preferences and concerns
- Self-imposed organization policies
- Risk-based scenarios and best practices

## Common requirements:

- Purpose limitation
- Data subject consent
- Right to rectification, erasure, and restriction
- Data minimization
- Storage limitation
- ...



# Privacy requirements



## Source of requirements:

- Privacy regulations: **GDPR**, CCPA, DCIA, PIPL
- User preferences and concerns
- Self-imposed organization policies
- Risk-based scenarios and business requirements

## Common requirements:

- **Purpose limitation**
- **Data subject consent**
- Right to rectification, erasure and portability
- Data minimization
- Storage limitation
- ...

### Art. 5 GDPR

## Principles relating to processing of personal data

1. Personal data shall be:
  - (a) processed lawfully, fairly and in a transparent manner in relation to the data subject ('lawfulness, fairness and transparency');
  - (b) collected for specified, explicit and legitimate purposes and not further processed in a manner that is incompatible with those purposes; further processing for archiving purposes in the public interest, scientific or historical research purposes or statistical purposes shall, in accordance with [Article 89\(1\)](#), not be considered to be incompatible with the initial purposes ('purpose limitation');
  - (c) adequate, relevant and limited to what is necessary in relation to the purposes for which they are processed ('data minimisation');



## General Data Protection Regulation

*Personal data shall be collected for specified, explicit and legitimate purposes and not further processed in a manner that is incompatible with those purposes.*

(‘Purpose limitation’) — Art. 5 §1 (b)

*Processing shall be lawful only if the data subject has given consent to the processing of his or her personal data for one or more specific purposes.*

(‘Data subject consent’) — Art. 7 §1

# Handling privacy requirements

## Current challenges



**Specification:** Absence of effective languages and tools.

# Handling privacy requirements

## Current challenges



**Specification:** Absence of effective languages and tools.



**Implementation:** Ad hoc, no guarantee of correctness.

# Handling privacy requirements

## Current challenges



**Specification:** Absence of effective languages and tools.



**Implementation:** Ad hoc, no guarantee of correctness.

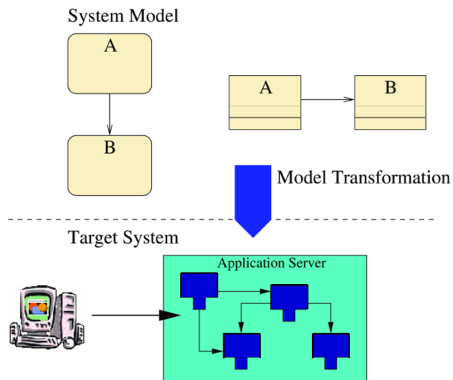


**Evolution/Maintenance:** error prone and time consuming.

# Our solution: **Model-driven development**

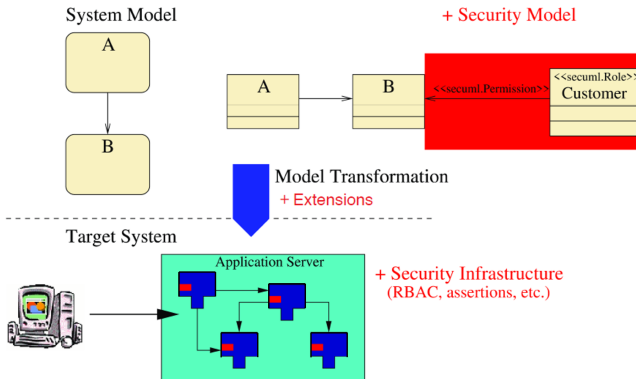


# Model-driven Development



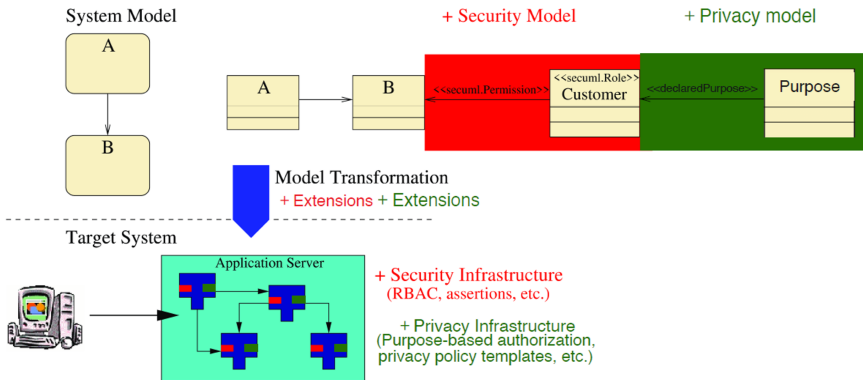
# Model-driven Security

Lodderstedt et al. have specialized a new model-driven development methodology that supports **security**.



# Model-driven **Security** and **Privacy**

Our work: **purpose limitation** and **data subject consent** requirements



# Handling privacy requirements

using Model-driven Privacy



**Specification:** Formal language with precise semantics.

# Handling privacy requirements

using Model-driven Privacy



**Specification:** Formal language with precise semantics.



**Code generation:** Cross-cutting, correct by design.

# Handling privacy requirements

using Model-driven Privacy



**Specification:** Formal language with precise semantics.

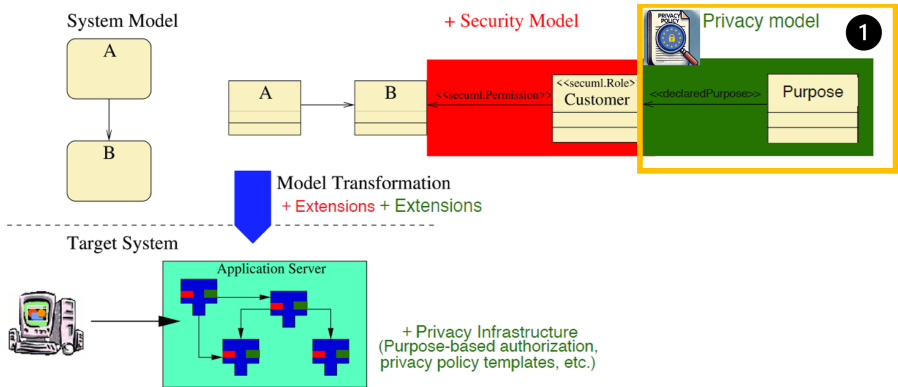


**Code generation:** Cross-cutting, correct by design.

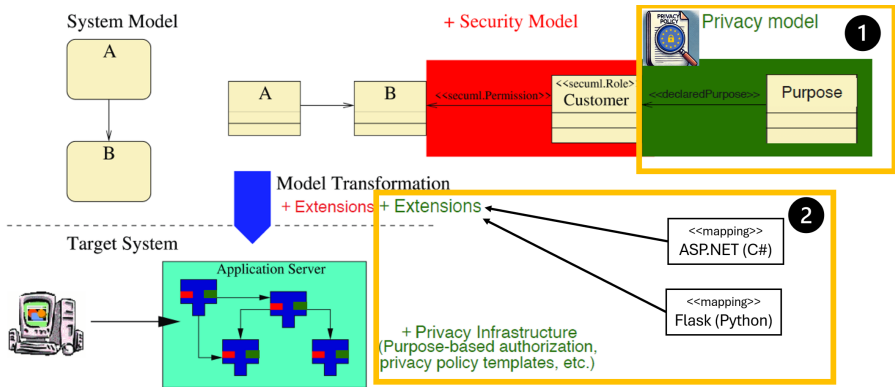


**Evolution:** Change model(s), regenerate code.

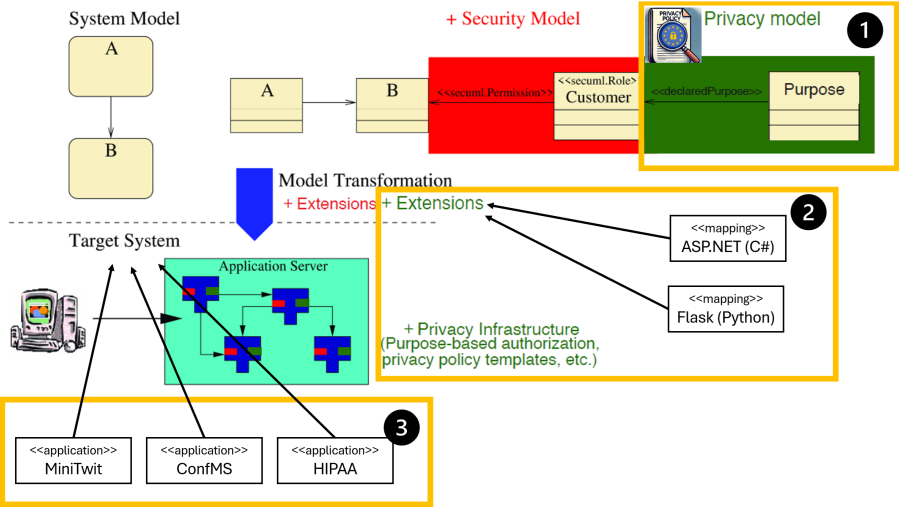
# Main contribution



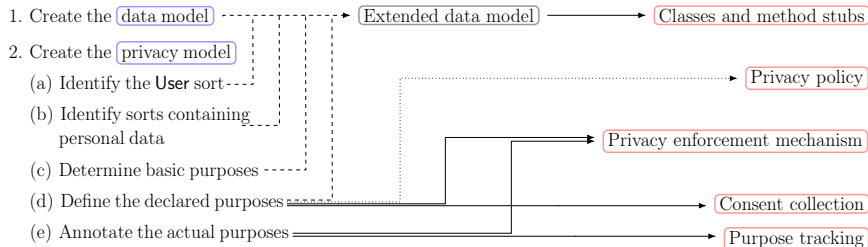
# Main contribution



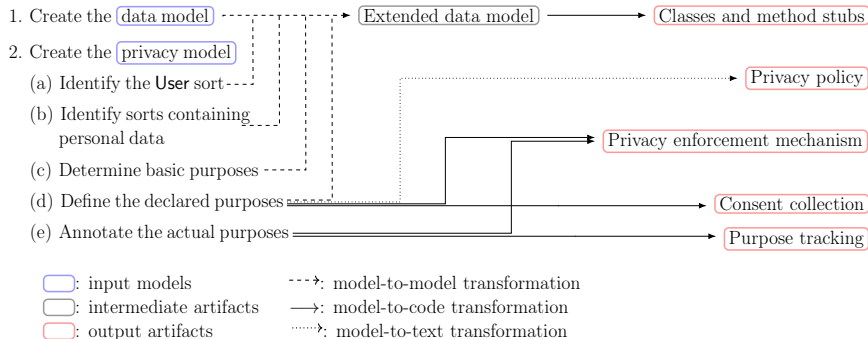
# Main contribution



# Methodology



# Methodology



# Examples

## Conference Management System – Data model

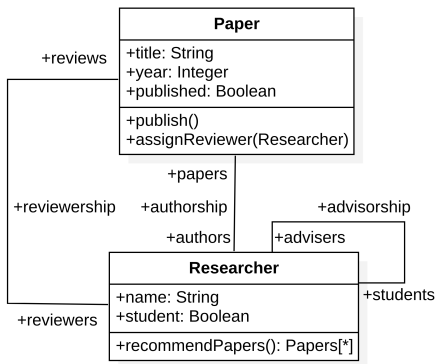
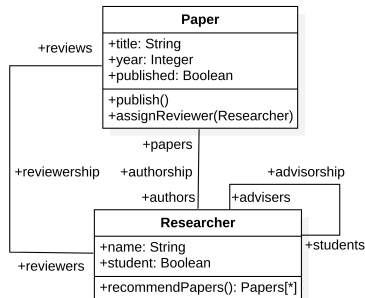


Figure: Data model (UML class diagram)

# Examples

## Conference Management System – Privacy model

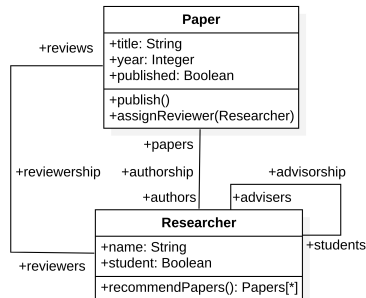
```
1  {
2    "personalData": ["Researcher"], // (2.b.) Identifying personal data
3    "purposes": [
4      {
5        "name": "RecommendPapers",
6        "endpoints": [
7          {
8            "class": "Researcher",
9            "met": "recommendPapers"
10          }
11        ]
12      }
13    ],
14    "policy": [
15      {
16        "purpose": "RecommendPapers",
17        "action": "read",
18        "resources": [
19          {
20            "class": "Researcher",
21            "ends": "authors"
22          }
23        ],
24        "constraint": "self.student"
25      }
26    ]
27  }
```



# Examples

## Conference Management System – Privacy model

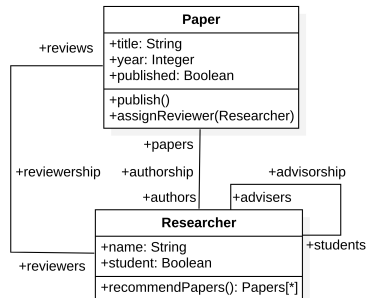
```
1  {
2    "personalData": ["Researcher"], // (2.b.) Identifying personal data
3    "purposes": [ // (2.c) Determining (basic) purposes
4      {
5        "name": "RecommendPapers",
6        "endpoints": [
7          {
8            "class": "Researcher",
9            "met": "recommendPapers"
10         }
11       ]
12     },
13   ],
14   "policy": [
15     {
16       "purpose": "RecommendPapers",
17       "action": "read",
18       "resources": [
19         {
20           "class": "Researcher",
21           "ends": "authors"
22         }
23       ],
24       "constraint": "self.student"
25     }
26   ]
27 }
```



# Examples

## Conference Management System – Privacy model

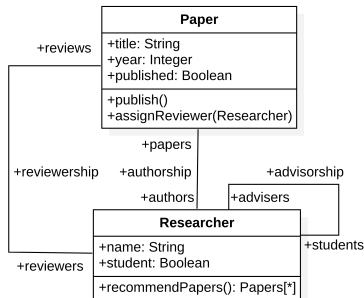
```
1  {
2    "personalData": ["Researcher"], // (2.b.) Identifying personal data
3    "purposes": [ // (2.c) Determining (basic) purposes
4      {
5        "name": "RecommendPapers",
6        "endpoints": [
7          {
8            "class": "Researcher",
9            "met": "recommendPapers"
10         }
11       ]
12     },
13   ],
14   "policy": [
15     // (2.d.) Defining declared purposes
16     {
17       "purpose": "RecommendPapers",
18       "action": "read",
19       "resources": [
20         {
21           "class": "Researcher",
22           "ends": "authors"
23         }
24       ],
25       "constraint": "self.student"
26     }
27   ]
28 }
```



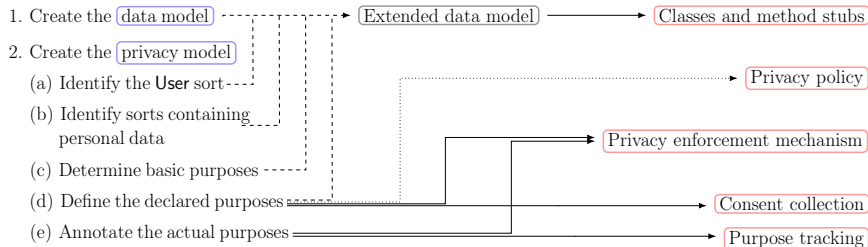
# Examples

## Conference Management System – Privacy model

```
1  {
2    "personalData": ["Researcher"], // (2.b.) Identifying personal data
3    "purposes": [ // (2.c.) Determining (basic) purposes
4      {
5        "name": "RecommendPapers",
6        "endpoints": [ // (2.e.) Annotating actual purposes
7          {
8            "class": "Researcher",
9            "met": "recommendPapers"
10         }
11       ]
12     },
13   ],
14   "policy": [
15     { // (2.d.) Defining declared purposes
16       "purpose": "RecommendPapers",
17       "action": "read",
18       "resources": [
19         {
20           "class": "Researcher",
21           "ends": "authors"
22         }
23       ],
24       "constraint": "self.student"
25     }
26   ]
27 }
```



# Methodology



 : input models

 : intermediate artifacts

 : output artifacts

--->: model-to-model transformation

—>: model-to-code transformation

.....>: model-to-text transformation

# Examples

## Conference Management System – Extended data model

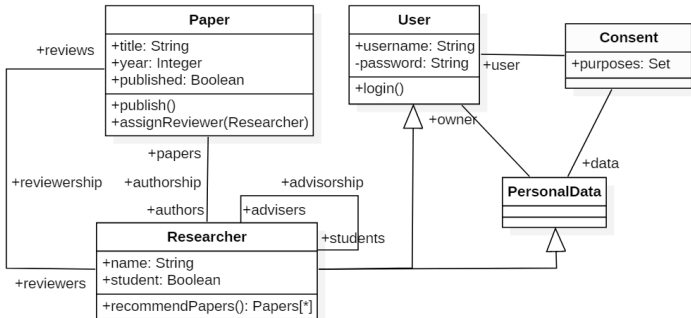
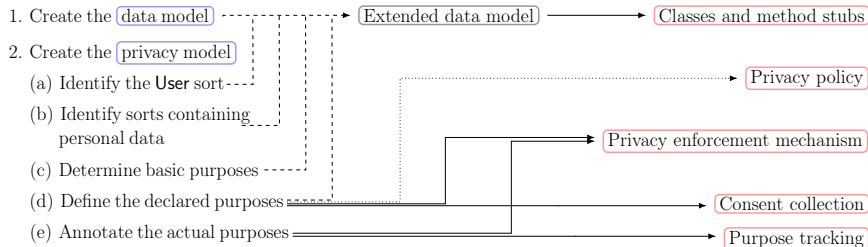


Figure: Data model (extended with privacy classes)

# Methodology



# Examples

## Conference Management System – Generated artifacts

- Methods are generated as empty stubs annotated with their purposes.

```
1 @label(['RecommendPapers']) // Actual purpose annotation
2 def recommendPapers():
3     // TODO: Implement method stub
```

# Examples

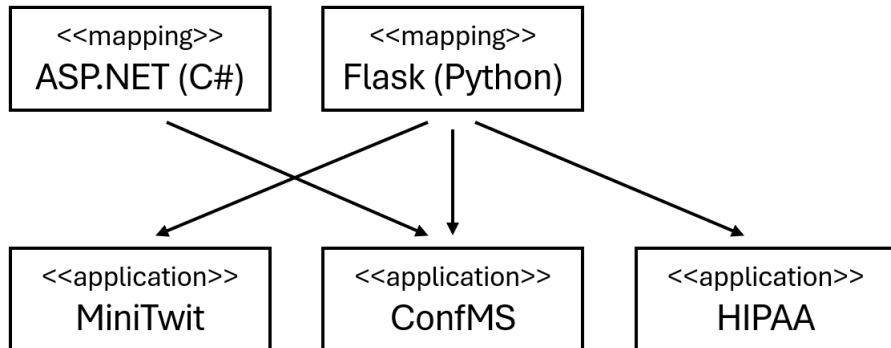
## Conference Management System – Generated artifacts

- **Privacy notice** is generated automatically.

| Privacy notice                                                                                                                      |        |
|-------------------------------------------------------------------------------------------------------------------------------------|--------|
| Declared purposes                                                                                                                   |        |
| Policy                                                                                                                              | Action |
| We use fields ['authors', 'name', 'advisers', 'reviews'] of your Researcher personal data for the purpose of AssignReviewer if true | Allow  |
| We use fields ['name'] of your Researcher personal data for the purpose of PublishPaper if true                                     | Revoke |
| We use fields ['authors', 'name'] of your Researcher personal data for the purpose of RecommendPapers if you are a student          | Allow  |

# Implementation

Model transformations:



Case study applications:

# Evaluation

(Selected<sup>1</sup>) Research questions



## Development effort

How much developer effort is required to use our approach?



## Performance overhead

How much runtime overhead does our approach incur?

---

<sup>1</sup>More in the paper



# Evaluation

Development effort (on Conference Management System case study)

- Set up: Define models → Generate code → Implement methods.



# Evaluation

Development effort (on Conference Management System case study)

- Set up: Define models  $\rightarrow$  Generate code  $\rightarrow$  Implement methods.
- Define models:
  - ▶ 13 LoC (data model)
  - ▶ 20 LoC (security + privacy model).



# Evaluation

Development effort (on Conference Management System case study)

- Set up: Define models  $\rightarrow$  Generate code  $\rightarrow$  Implement methods.
- Define models:
  - ▶ 13 LoC (data model)
  - ▶ 20 LoC (security + privacy model).
- Generate code:
  - ▶ 1954 LoC (C#)
  - ▶ 731 LoC (Python)



# Evaluation

Development effort (on Conference Management System case study)

- Set up: Define models  $\rightarrow$  Generate code  $\rightarrow$  Implement methods.
- Define models:
  - ▶ 13 LoC (data model)
  - ▶ 20 LoC (security + privacy model).
- Generate code:
  - ▶ 1954 LoC (C#)
  - ▶ 731 LoC (Python)
- Implement methods:
  - ▶ 344 LoC (C#)
  - ▶ 142 LoC (Python)



# Evaluation

Development effort (on Conference Management System case study)

- Set up: Define models → Generate code → Implement methods.
- Specification: 33 LoC
- Implementation:
  - ▶ 2298 LoC (C#, 85% generated)
  - ▶ 873 LoC (Python, 84% generated)

Developers need to implement **only** 15-16% of the overall codebase.



# Evaluation

Performance overhead (on MiniTwit case study)

- open-source, unsecured application (baseline)



# Evaluation

## Performance overhead (on MiniTwit case study)

- open-source, unsecured application (baseline)
  - ▶ manually implement privacy checks (secured)



# Evaluation

## Performance overhead (on MiniTwit case study)

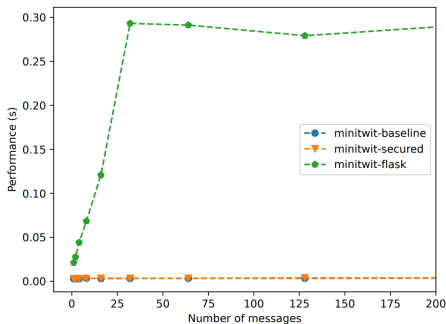
- open-source, unsecured application (baseline)
  - ▶ manually implement privacy checks (secured)
  - ▶ implement application our approach (flask)



# Evaluation

## Performance overhead (on MiniTwit case study)

- open-source, unsecured application (baseline)
  - ▶ manually implement privacy checks (secured)
  - ▶ implement application our approach (flask)
- execute `public_timeline()` endpoint (pagination for 30 messages).



Performance overhead is modest compared to manual implementation.

# Future Work

- extend to other class of privacy requirements.

# Future Work

- extend to other class of privacy requirements.
- proving the correctness of the transformation.

# Future Work

- extend to other class of privacy requirements.
- proving the correctness of the transformation.
- conduct a user (i.e., developer) case study.

# Questions?

© MARK ANDERSON WWW.ANDERSTOONS.COM



"Before I write my name on the board, I'll need to know how you're planning to use that data."